

Part II (For Grades D to A)
DD2395 Computer Security
Exam 2021-01-15
14.00 – 17.00 regular time
(14.00 – 18.30 for funka code R1)

The only resources allowed are the course materials (including course books and own notes). This part is only graded if Part I resulted in an E. Bonus points that have not been used up in the Part I of the exam (multiple choice, to get grade E) can be used as points here. The preliminary grading is as follows:

- E: 0-9 points
- D: 10-13 points
- C: 14-17 points
- B:18-21 points
- A: 22 or more points.

includes solutions.

1 Social engineering. [5 points]

In Summer 2020, more than a hundred accounts of famous Twitter users were taken over by attackers who tweeted from these accounts to promote a Bitcoin scam. Researchers from security companies suspect that this was done using "vishing", i.e., phishing with voice mail or phone calls.

Consider this (ficticious) scenario. Soren, a social engineer, wants to try this for "kvittr.nu", the local competitor. He searches LinkedIn profiles for people working for Kvittr and their positions. For some of the promising ones, he looks them up on sites like eniro, merinfo, hitta, and ratsit. He now has phone numbers, birthdates, addresses, apartment, car, cohabitants and other information from which he can infer or make educated guesses about the demographics and preferences of some key Kvittr employees. He calls the first Target, Tanja:

Soren: Hej! I hope I'm not disturbing you at lunch, but this is quite urgent. Am I speaking with Tanja? My name is Anders Ericsson, I'm calling from Bahnhof. As you probably know from your housing association, Brf Kajen, there are plans to install fiber in all the apartments in your house on Strandvagen 111. This will cause some disruption in your network connection for the next few days.

Tanja: Yes, there was something in the last house meeting minutes, but I thought that's going to happen much later! We're working from home and our older children have distance learning, we can't have the network down for several days.

Soren: I know! It's really difficult these days, we're also at home all the time with the kids. But, you know what, we have agreements with some companies, perhaps we're lucky and yours is on the list. Some pay for their employees to have a fallback solution set up in case the network is out. Where do you work?

Tanja: I work with Kvittr.

Soren: That's great, I just helped a customer from there, so I know Kvittr has a premium agreement with us for just such cases. Just spoke with Klara Kverelius, I think her name was, this morning and set up a fallback system for her and she was very happy as it was faster than what they had in the house, but I guess it's a big organization and you don't know everyone there.

Tanja: Klara! That's my second-line manager! What do I need to do to get this set up?

Soren: I'll text you a link to the form that you can fill out. You log in with your Kvittr username and password. Then it goes via our Kvittr interface and the billing is handled internally, so you don't have to worry about it.

Tanja: Thanks a lot, I'll do it right away.

1a List four of the techniques the social engineer employs and for each briefly the evidence in the scenario.

Solution: 4 out of the following (or possibly other valid response that's not listed): gather information beforehand (evidence: collect info from social media sites etc.), make up a pretext/story (evidence: talk about a fiber installation and consequent problems), create a problem and solve it (evidence: network will be out, but can install backup solution), distract from systematic thinking by creating time pressure (evidence: call at lunch, say network will be out), create rapport (evidence: commiserate, open up about own family, friendly), bring in support from authority (evidence: pretend manager has used the service), use collected information to increase credibility (evidence: housing association minutes, detailed address), altercasting (evidence: put target in victim role by potential network outage, put social engineer in helper role by offering solution).
Grading: 2points (A) for 4 correct techniques with correct evidence, 0.5 points each, no added incorrect information. 1 point (E) for at least 2 reasons with correct evidence, some additional mistakes allowed.

1b List two of the human traits these techniques exploit and for each briefly the evidence in

the scenario.

Solution: 2 out of the following (or possibly other valid response that's not listed): reactance, i.e., agreement to relieve restrictions (evidence: threat of network outage, agreement to click link and log in), attribution, i.e., interpreting attackers behavior as appropriate for ISP support (evidence: not asking for too much information, helpful demeanor, knows plans by housing association but not where she works or other unlikely information. The target doesn't express doubt in the role/credentials of the social engineer), liking (evidence: apparently common ground of having to work from home with older children not in school, friendly and helpful persona), trust in peers or authorities (evidence: Klara's example).
Grading 2 points (A) for 2 correct traits with correct reasoning (doesn't have to be as verbose as the sample solution), no added incorrect information. 1 point (E) for 1 correct trait with correct reasoning (doesn't have to be as verbose as the sample solution), no added incorrect information.

1c What is the effect of the social engineering attack, i.e., what can the attacker do now that they couldn't do before?

Solution: They now have the login credentials of a Kvittr employee and can use that to make any changes the target herself can make and have read access to anything she can see. In addition to using her access rights, they can impersonate her in communications. They can leverage her account to gain access to others by another round of social engineering.
Grading: 1 point (E) for getting this mostly right.

2 Memory safety. [3 points] The following program "implements" a procedure to execute a program as root. Each user, including root, has a name, pwd, home folder, and a flag. The flag indicates if the user can execute programs as root via sudo. The procedure receives a user structure as parameter, which consists of the data of the user that is attempting to execute another program as root. If the user is not authorized, the procedure prints on screen the password of the user. Moreover, the procedure releases the memory used for the input datastructure, creates a temporary structure with the data of root, and logs the failed attempt. The log procedure requires data of root to append a line to the log, which may be stored in root's home directory.

```
struct user {
   char name[10];
   char pwd[10];
   char home[10];
   int can_sudo;
 };

user * get_root() {
  user * root = malloc(user);
  strcpy(root.name, "root");
  strcpy(root.pwd, "1234");
  strcpy(root.home, "/");
  root.can_sudo = 1;
  return root;
}

bool sudo (user * p) {
  if (!(*p).can_sudo) {
     char [10] user_name;
     strcpy(user_name, *p.name);
```

```
      free(p);
      user * root = get_root();
      log_failed_attempt(root, user_name);
      free(root);
      return false;
   }
   return true;
}

bool exec_as_root(user * p) {
    if (!sudo(p))
       printf("you cannot execute applications with root privilege,
            your password is %s", (*p).pwd);
    ...
}
```

The procedure has a bug which can cause the leakage of some data of root when the user is not authorized and printf is executed.

2a Explain what is leaked and the cause.

Solution: The program leaks the root password. The cause is that the user datastructure is freed in the sudo function but is later used-after-free in the printf:

1. when sudo frees the user structure, the corresponding memory area is made free for reuse
2. the following malloc (in get_root) may return exact that region of memory
3. get_sudo may write the root information (including password) into that region
4. when sudo frees the root structure, the corresponding memory area is made free for reuse, but its content is not overwritten
5. using the old pointed p in the printf lead to accessing the memory area that has been used for storing the root password.

2b Propose a solution to fix the procedure.

Solution: Anything that does no cause a use-after free. E.g. you can avoid freeing in sudo and freeing the datastructure after printf. Alternatively, copy the password in a temporary variable before invoking sudo and use the temporary variable in printf.
Grading

- 1 point for saying root password and use-after-free (or similar terms)
- 1 point for explaining
- 1 point for proposing a reasonable solution

3 Side channels. [3 points] A system implements an online blind auction. Each bidder can submit sealed bids (i.e., no bidder knows the bids of any other participant). Bidders can submit bids multiple times until the auction's deadline. After the deadline, the highest bidder wins and pays the highest price that she has submitted.
The system keeps an ordered array LOG of bids (of size N) and uses global variable B to record the number of bids.

```
void submit_bid(bidder, bid) {
     i = 0;
     while (i < N and i < B and LOG[i].value<bid) {
           i+=1
     }
     if (i == N) {
        return;      // Log limit exceeded
     }
     curr = {user:= bidder, value:= bid};
     B+=1;
     while (i<B) {
           next  = LOG[i];
           LOG[i]=curr;
           curr = next;
           i+=1
     }
}
```

3a Explain how a remote adversary can use a timing side channel to learn information about the other bidders.

Solution: Execution time depends on how many bids are higher/lower than the adversary bid. In the following we assume that the execution time of the body of the first loop is less than the execution of the second one. If the current bid is the n-th highest bid, then the first while loop is executed $B - n$ times and the second loop is executed n times. If The bidder can also use this information to learn the lowest bid. He keeps submitting decreasing bids until the execution time does not decrease. Similarly, The adversary can learn the highest bid by submitting increasing bids until the execution time does not increases.

3b Mention which information the adversary can learn.

Solution: Number of bids lower than submitted value and number of bids higher than submitted value.

3c Propose a countermeasure to avoid this channel.

Solution: There are several option.

- evaluate worst case execution time of the system and wait at the end of the function
- guarantee that execution time of both loops are the same
- change loops body to execute both loops the same amount of time (quite complicated for this example)
- do not store the bids ordered

Grading

- 1 point if he mention that execution time depends on how many time is executed the first loop and how many times is executed the second one

- 0.5 point if he mention that the number of higher/lower bids are leaked.
- 0.5 point if he mention that the total number of bids is leaked.
- 1 if he mention any reasonable countermeasure (cache related operations are not relevant here).

4 Hash functions. [5 points]
Let $x = x_1 \dots x_n$ be an input of n blocks of 256 bits each. $H_+(x) = x_1 + H_\oplus(x_2 \dots x_n)$ if $n > 1$ and $H_+(x) = x_1$ if $n = 1$, $H_\oplus(x) = x_1 \oplus H_+(x_2 \dots x_n)$ if $n > 1$ and $H_\oplus(x) = x_1$ if $n = 1$, with $+$ being addition modulo 2^{256}, and $\oplus$ being bitwise xor. (e.g. $H_+(x_1x_2x_3x_4) = x_1 + (x_2 \oplus (x_3 + x_4))$).

4a Is H_+ a secure hash function?

Solution: No

4b For each requirement of secure hash functions, disprove the requirement or argue why the requirement is met.

Solution:

- One-way: No. given h it is easy to find x such that $H_+(x) = h$. In fact $H_+(h) = h$.
- Weak collision resistance: No. Given x it is easy to find y such that $H_+(x) = H_+(y)$. In fact $H_+(x) = H_+(x, 0)$.
- Strong collision resistance: No, since it is not Weak collision resistance.

Grading

- 5 points if every property has been correctly *disproven* otherwise
- 2 points for every property has been correctly *disproven* otherwise
- 1 point for every property has been correctly stated (i.e. correct definition) and has been informally disproven, otherwise
- 1 point if student says that it is not weak-collision resistance and is not one way but they do not explain why.

5 Authentication and access control [5 points]
The Private E-Commerce Company wants to strengthen consumer privacy in the area of e-commerce. We have three entities; the Seller, the Shipper and the Buyer. The Seller sells the Product to the Buyer. The Seller then ships the Product to the Buyer using the Shipper's shipping service.

5a What access control policies do we need at the different steps? Why?

Solution: This part allows the students to "analyze system descriptions in terms of their security to identify vulnerabilities and predict their corresponding threats". They can do this at different levels, from the grading criteria:

E finding obvious problems with few mistakes,

C finding obvious problems correctly

A finding subtle problems correctly

B and D are for in-between cases.
An obvious problem is that the Product can be stolen (like the Shipper must keep the Product secure). A more subtle problem is that not just any Shipper can come and fetch the product: a thief might try to impersonate the Shipper. Another subtle problem is that the Shipper can't just deliver to anyone on the destination address: a thief might try to impersonate the recipient. But there can be other problems too that the students identify.

5b What solutions exist to authenticate the needed attributes? Why do they solve the problem?

Solution: This part allows students to "select counter-measures to identified threats and argue their effectiveness". They can do this at different levels:

E with some appropriate counter-measures and basic argumentation, with few mistakes

C with some appropriate counter-measures and basic argumentation, correctly

A with arguably most appropriate counter-measures and nuanced argumentation.

B and D are for in-between cases.
An appropriate counter-measure is to check identity cards. This solves the problem as only authorized people can pass access control checks. However, this is not the most appropriate solution, we don't need to know the identities. The Seller only needs to know that the Shipper is the legitimate shipper, *i.e.*, that he works for the right shipping company. The Shipper don't need to know the Seller's identity either, nor the Buyer's identity — the Shipper only needs to know if the Buyer is the correct destination.
So, an example of a more appropriate solution for that particular part is that the Buyer get a secret from the Seller. The Seller also shares the secret with Shipper, who can then confirm the Buyer by asking the Buyer for it.
The name of the company (Private E-Commerce) serves as a hint for the students to not fall into the trap of how things work in the real world right now.

5c How is this problem solved today?[1] What are the advantages and drawbacks compared to your solution? What side-effects do they have?[2] Which one would you choose and why?

Solution: This allows the students to "compare counter-measures and evaluate their side-effects". This can be done at different levels:

E from list with given effects, with few mistakes,

C with basic argumentation and list of side effects,

A setting up own criteria, nuanced argumentation, comprehensive list of side effects.

[1] By the normal postal service.
[2] At least one is pointed out by the Private E-Commerce Company in the scenario.

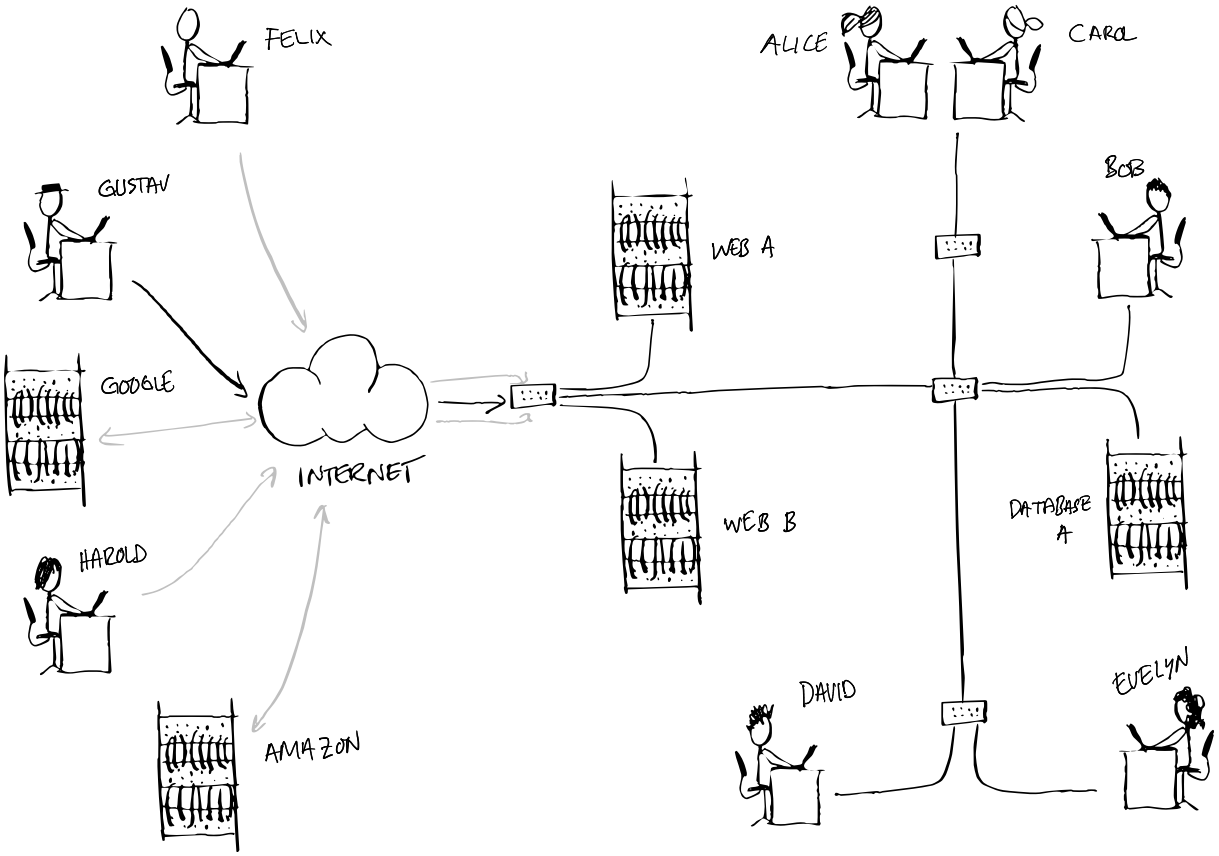


Figure 1. A network topology for a fictive organization.

B and D are for in-between cases.
They are implicitly given a list of solutions (how the problem is solved today, by the postal service) and side-effects (the scenario of Private E-Commerce).
The obvious side-effect of the current system is that the Shipper learns who buys what from whom. By authenticating with ID cards, we reveal even more information than necessary.
The students should also analyze their own solutions and the side-effects they imply.
Furthermore, they can set up own criteria, such as complexity. With checking IDs, all data is on the parcel. With the solution suggested in previous subproblem, the Buyer must keep track of the code. What if that code is lost?
Scoring: A gives 5 points, B gives 4 points, . . . , E gives 1 point. The final score of this question is the average score of the subproblems above (5a, 5b, 5c)

6 Intrusion detection and prevention (firewalls) [5 points]

Consider the network in Figure 1.
Alice, Bob, Carol, David and Evelyn all work in offices inside the physical location of the organization. Felix and Harold are working remotely[3]. Gustav is not affiliated with the organization, he's a random malicious dude on the Internet (he wears a black hat).
The servers Web A and Web B are public-facing servers. Providing services for customers or just hosting the company web pages or mail servers. The web servers must access the internal database Database A for some services they host.

[3]Yes, it's pre-COVID-19, while people still worked from offices.

You are tasked with intrusion detection and prevention in this organization.

6a What threats do you see?

Solution: This part allows the students to "analyze system descriptions in terms of their security to identify vulnerabilities and predict their corresponding threats". They can do this at different levels, from the grading criteria:

E finding obvious problems with few mistakes,

C finding obvious problems correctly

A finding subtle problems correctly

B and D are for in-between cases.
An obvious problem is that Gustav will try to attack the organization in some way. It's not as obvious that he might collude with some of the employees. Or that Gustav will subvert the public servers and plant malware only in requests from internal computers. Another subtle problem is internal attackers, *e.g.*, trying to exfiltrate data from internal systems.

6b Where would you place what defences?

Solution: This part allows students to "select counter-measures to identified threats and argue their effectiveness". They can do this at different levels:

E with some appropriate counter-measures and basic argumentation, with few mistakes

C with some appropriate counter-measures and basic argumentation, correctly

A with arguably most appropriate counter-measures and nuanced argumentation.

B and D are for in-between cases.
Some types of firewalls can only solve some types of problems and only if they are situated in a suitable location. Likewise for intrusion detection systems. Do their defences solve the problem?

6c What are the advantages and disadvantages of your defence solution? How does it compare to alternatives?

Solution: This allows the students to "compare counter-measures and evaluate their side-effects". This can be done at different levels:

C with basic argumentation and list of side effects,

A setting up own criteria, nuanced argumentation, comprehensive list of side effects.

B and D are for in-between cases.
What side-effects do their solutions yield? How do they compare them to alternative solutions? For instance, deploying deep packet-inspection firewalls on every host might be secure, but degrades performance.
We have intentionally left quite some wiggle room in the specification. This is to allow you to do contrasting analyses more easily.
Scoring: A gives 5 points, B gives 4 points, . . . , E gives 1 point. The final score of this question is the average score of the subproblems above (6a, 6b, 6c)